

Investigating An Account Compromise: Social Networks, Social Engineering, OSINT and Phishing

About This Investigation

Afomiya Storm is a rising **Social Media Influencer** who gains a new role at CloutHaus. Afomiya receives a phishing email disguised as an industry collaboration email, which left her vulnerable to **account compromission**.

We will be investigating the root cause, attack vectors, affected information and assets, tracing the phishing attack. We will also include Incident Response Remediation Strategies how such an Incident could be prevented.

Tools, Technologies and Methodologies

Microsoft Azure Data Explorer

Kusto Query Language

Phishing Identification

Threat Hunting

Indications of Compromise

Afomiya, a social media influencer, publishes regular content on her Instagram account

She uses her personal email for business use

afomiya.storm@gmail.com

Afomiya receives a high volume of emails regarding her career projects about brands, vlogs, collaboration and promotion opportunities.

However, with all of these, comes the possibility and correct identification of a genuine email and Phishing email.

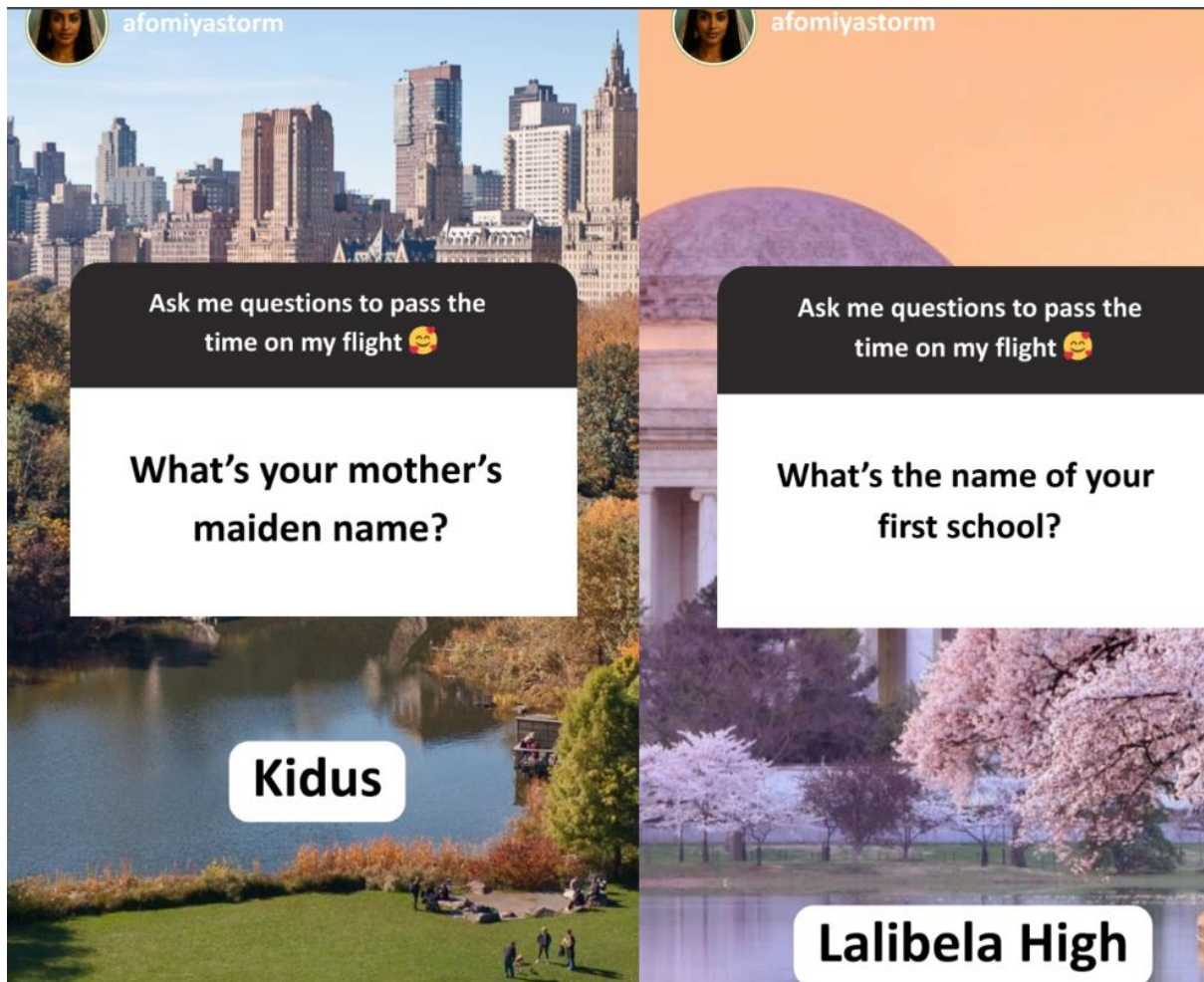
All of the below are considered signs of Phishing intent within an email:

- A.** The email contains urgent or threatening language, pressuring her to act quickly, such as "Immediate action required" or "Deadline in 24 hours."
- B.** The email asks for sensitive information like her password, credit card details, or social security number.
- C.** The email comes from a domain name that looks suspicious or doesn't match the legitimate brand's official domain.
- D.** The email has generic greetings like "Dear Customer" instead of addressing her by name or title.
- E.** All of the above.

Afomiya does a Q&A with her followers via a live stream whilst travelling, she is asked several specific and personal questions that are closely aligned towards commonly used **Account Access and Recovery security questions**.

These security questions could be used to access her Instagram account which is linked to her **personal email address**. The specific security questions can be confirmed by the attacker requesting a **password reset using Afomiya's email address**.





Personal and **Confidential Information** can often be visibly and publicly found on such social media accounts in various methods, given inadvertently, including tags and specific posts about occasions etc.

This is known as **Social Engineering and Information Gathering** in the form of **Passive Foot Printing**.

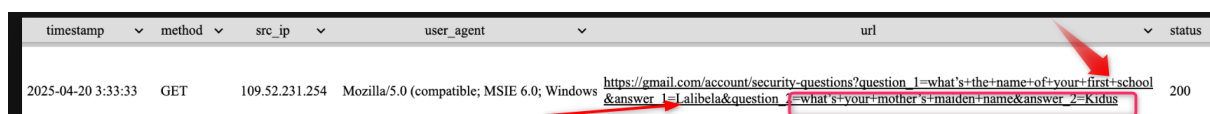
Collating the information to **exploit** the target's Social Media accounts can be known as **Open-Source Intelligence OSINT**.

Which is the process of gathering and gaining publicly visible confidential information of an adversary by an attacker.

We can see from the Authentication Logs that the below Security Questions and Answers:

The Name of Afomiya's first school and their Mother's Maiden name

Were used and entered by an attacker when requesting a **password reset using Afomiya's email.**



timestamp	method	src_ip	user_agent	url	status
2025-04-20 3:33:33	GET	109.52.231.254	Mozilla/5.0 (compatible; MSIE 6.0; Windows	https://gmail.com/account/security-questions?question_1=what's+the+name+of+your+first+school+&answer_1=Lalibela&question_2=what's+your+mother's+maiden+name&answer_2=Kidus	200

Further to entering the correct answers to the security questions, the attacker was asked for a **One-Time Passcode OTP / Multi Factor Authentication (MFA) code.**

Which is usually retrieved from and sent to either the account owner's phone number or their email address.

Unsuccessful retrieval of this code prevents the successful completion of the password reset process.

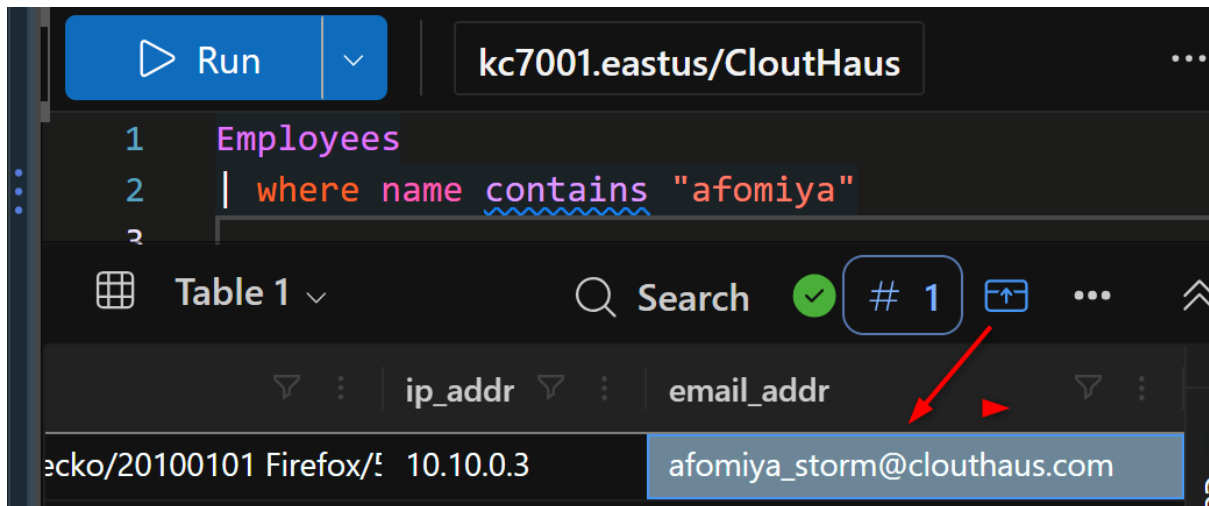
Afomiya gets approached and employed by Clout Haus, a brand management company.

In which she gets an official business email, Claut Haus logs all data and activity within Microsoft Azure Data Explorer.

Querying Afomiya's user and retrieving their business email and account details using KQL.

Employees

| where name contains "afomiya"



Afomiya's account details:

afomiya_storm@clouthaus.com

Username

afstorm

Role

Influencer Partner

User's Host Name

OQPA-DESKTOP

Internal IP

10.10.0.3

The target's role can be an important aspect of attacker **reconnaissance / information gathering**

Based on the target's role, the attacker would craft specifically tailored phishing emails that would be deemed relevant and of the target's interest.

Querying Afomiya's role:

Employees

| *where name contains "afomiya"*

| *distinct role*

Afomiya's confirmed role within **CloutHaus** is an **Influencer Partner**.

Reviewing whether **MFA** is in place for the user as **Best Practise Security**, via the Employees table:

Employees

| *where username contains "afstorm"*

| *distinct mfa_enabled*

MFA shows as **False** for Afomiya's user.

The screenshot shows a SQL query interface with a dark theme. At the top, there is a blue 'Run' button and a dropdown menu. To the right, the database path 'kc7001.eastus/CloutHaus' is displayed. The query is written in a multi-line editor with line numbers 1 through 4. The query text is: `1 Employees`, `2 | where username contains "afstorm"`, `3 | distinct mfa_enabled`, and `4`. Below the query editor, there is a toolbar with a table icon, the text 'Table 1', a search icon, the text 'Search', a green checkmark, and a button with '# 1'. At the bottom, a table is shown with a header row containing 'mfa_enabled' and a filter icon. The first row of data shows the value 'False', which is highlighted with a red rectangular box.

mfa_enabled
False

Querying the **legitimacy** and log details of the email that Afomiya received from Dior.

Email

| where recipient == "afomiya_storm@clouthaus.com"

| where subject contains "dior" or links contains "dior"

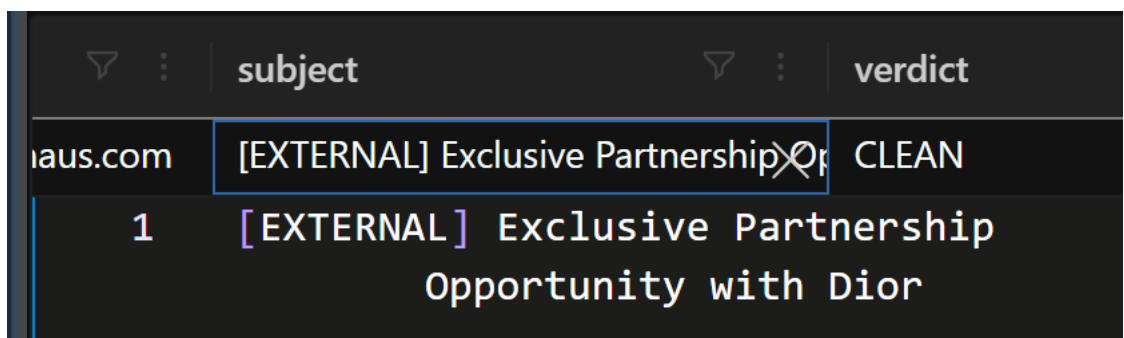
The sender's email was:

collabs@dior-partners.com

Co-operate organisations filter **Internal** emails vs **External** and often flag emails from external senders outside of the organisation within the subject line.

This would **not** have been the case with **Afomiya's personal email**.

We see that the email had been identified as **External** within the **subject** field.



	subject	verdict
clouthaus.com	[EXTERNAL] Exclusive Partnership Opportunity with Dior	CLEAN
1	[EXTERNAL] Exclusive Partnership Opportunity with Dior	

The link within the email, which is the threat and phishing attempt contains a log in request.

`["https://super-brand-offer.com/login"]`

Querying whether the user clicked the link, via the **Outbound Network Event** table logs.

OutboundNetworkEvents

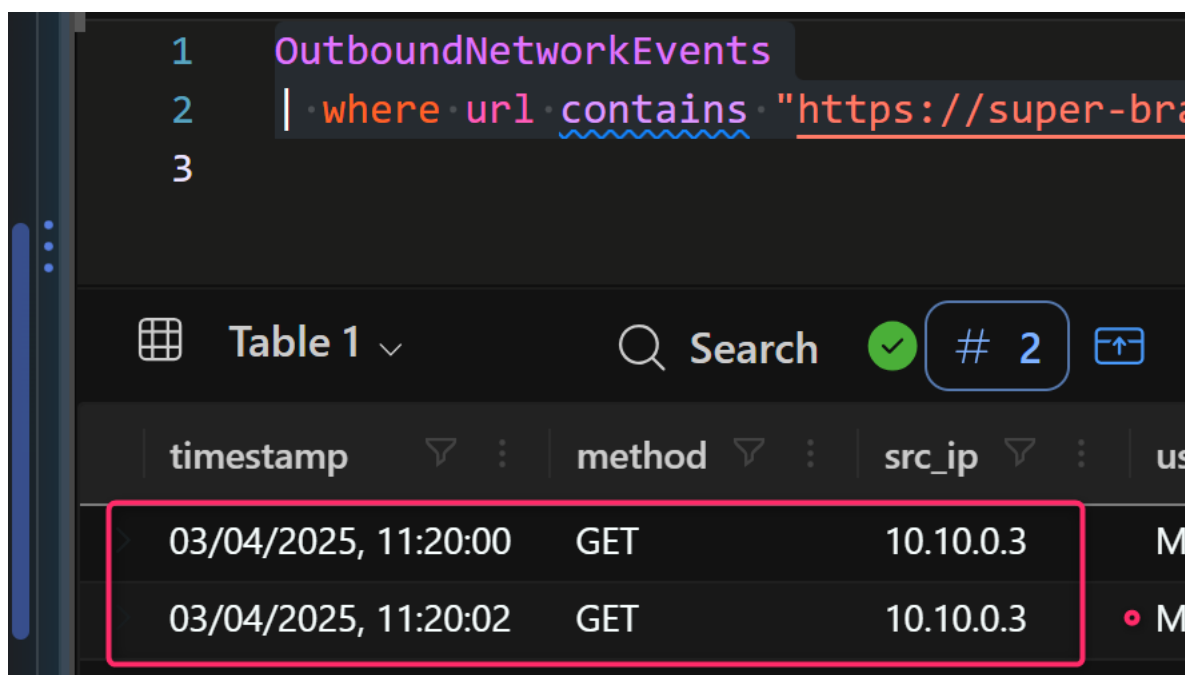
| where url contains "https://super-brand-offer.com/login"

The user's initiation of clicking the link was:

Timestamp

2025-04-03 T11:20:00.000Z

We can see that Afomiya clicked the link, processing a **GET** request along with their IPv4 Address.



```
1 OutboundNetworkEvents
2 | where url contains "https://super-brand-offer.com/login"
3
```

timestamp	method	src_ip	user
03/04/2025, 11:20:00	GET	10.10.0.3	M
03/04/2025, 11:20:02	GET	10.10.0.3	M

Credentials were entered by Afomiya on initiation of the link visited, we can see visibility of the username.

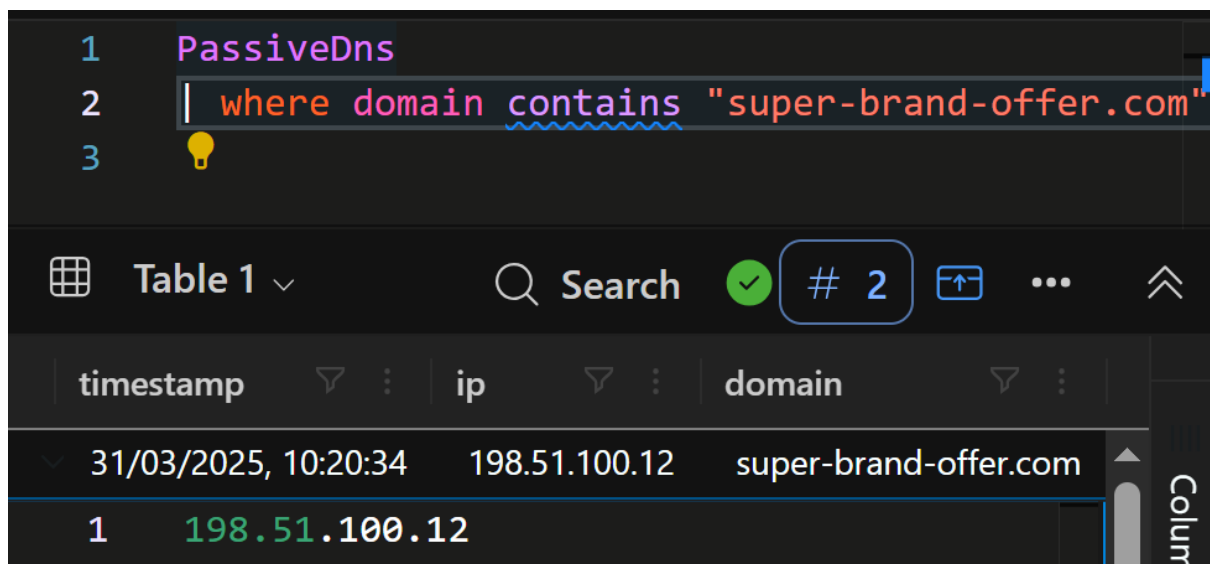
```
https://super-brand-offer.com/login?username=afstorm  
https://super-brand-offer.com/login?  
username=afstorm&  
password=*****
```

Querying the **Public IP** of the **Phishing site domain link** that the attacker used using **Passive DNS**.

PassiveDns

| *where domain contains "super-brand-offer.com"*

The domain resolves to the IP **198.51.100.12**



The screenshot shows the PassiveDns tool interface. At the top, a search query is entered: "where domain contains 'super-brand-offer.com'". Below the query, a table titled "Table 1" displays the search results. The table has three columns: "timestamp", "ip", and "domain". The first row of data shows the timestamp "31/03/2025, 10:20:34", the IP address "198.51.100.12", and the domain "super-brand-offer.com". Below this row, the IP address "198.51.100.12" is highlighted in green.

timestamp	ip	domain
31/03/2025, 10:20:34	198.51.100.12	super-brand-offer.com

Threat Hunting:

Querying how many **Malicious Domains** are hosted by the public attacker IP 198.51.100.12

Using **PassiveDNS** which will have a registry of the domains accessed, even if they're no longer in use.

PassiveDns

| *where ip contains "198.51.100.12"*

| *distinct domain*

3 domains are **linked** to the **malicious attacker IP 198.51.100.12**:

super-brand-offer.com

dior-partners.com

influencer-deals.net

The screenshot shows a terminal window with a dark background. At the top, there is a blue 'Run' button and a text input field containing 'kc7001.eastus/CloutHaus'. Below this, three lines of code are entered:

```
1 PassiveDns
2 | where ip contains "198.51.100.12"
3 | distinct domain
```

Below the code, there is a table header section with a grid icon, 'Table 1', a search icon, 'Search', a green checkmark, '# 3', and a refresh icon. The table has a single column header 'domain'. Below the header, three domains are listed, each preceded by a right-pointing arrow:

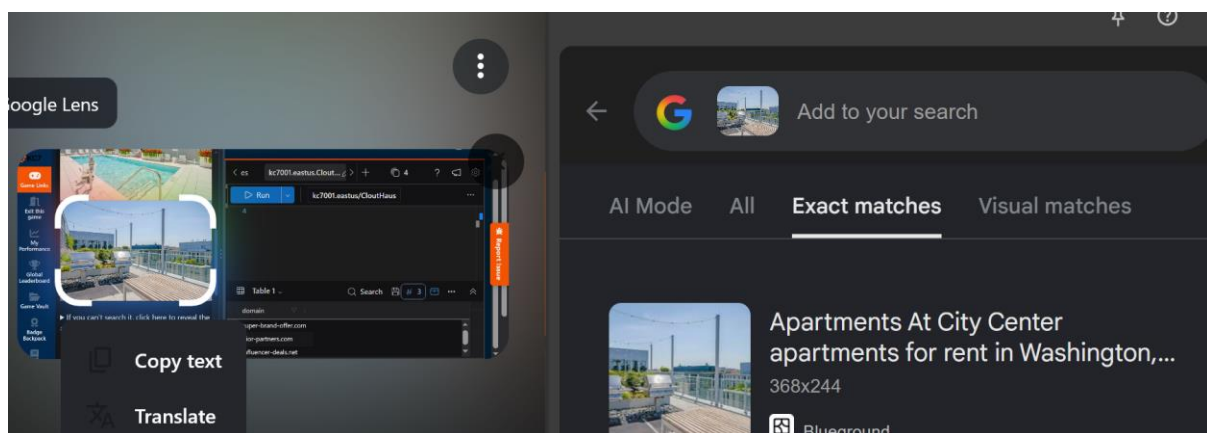
- super-brand-offer.com
- dior-partners.com
- influencer-deals.net

Further to Afomiya providing their credentials to the credential stealer within the Phishing email, due to **using the same long-term password with no MFA.**

The attacker gained **Unauthorised access to Afomiya's Instagram account** and proceeded to money launder followers, by promoting and sending messages regarding an Investment Funds Launch.

The Attacker gets the address of Afomiya's apartment based on their IG post of the apartment, where the attacker further used OSINT reverse search for the apartment details.

We Reverse Searched the image, via right click of the Image> google lens> exact matches



The exact name of the building is City Center Apartments

The scenario demonstrates **the physical security risks** that are associated with how personal content containing specific information, is posted online on public accounts. Leading to **physical unauthorised access and compromise.**

This was achieved by a combination of OSINT, An Information Disclosure Vulnerability and a Physical Escalation method.

Incident Response and Remediation:

Further to abnormalities and any sign of an **Indication of Compromise** on their Instagram account and in general:

Immediately review In App Log In Activity and Device Access

Reset Password to be Unique and not previously used

Remotely log out of all other devices

Enable MFA across all apps and services, email, Instagram etc

Limit publicly sharing confidential information and potentially have a private account, approving accounts that appear nonsuspicious.

Post or deliver follower awareness of recent Account

Compromisation to avoid further exploitation or affecting their followers.

Part 2

Further to the earlier successful Phishing attempt, the targets company email was accessed.

Incident Response Investigation:

We will use the Authentication, Network, and Email logs to uncover the intruder's activity, what information and assets were targeted, whether any data was exfiltrated.

Reviewed the log in attempts against Afomiya's username within the Authentication Events table.

AuthenticationEvents

| where username == "afstorm"

3 log in attempts were discovered, 2 failed to Afomiya's PC

Afomiya's Host Name: **OQPA-DESKTOP**

Afomiya's Public SRC IP **109.52.231.254**

1 of the 3 log in attempts was successful to the targets

ClautHaus business Email account, hosted on **MAIL-SERVER01**.

The log in was successful using the known attacker Public SRC IP 182.45.67.89

hostname	src_ip
MAIL-SERVER01	182.45.67.89
OQPA-DESKTOP	109.52.231.254
OQPA-DESKTOP	109.52.231.254

Successful log in

	username	result
compatible; MSIE	afstorm	Successful Login
Windows NT 10.0;	afstorm	Failed Login
Windows NT 10.0;	afstorm	Failed Login

Querying the Domains that are associated with the Malicious Src IP for Threat Hunting via **PassiveDNS**

PassiveDns

| where ip contains "182.45.67.89"

	timestamp	ip	domain
>	31/03/2025, 10:20:34	182.45.67.89	influencer-deals.net
	31/03/2025, 10:20:34	182.45.67.89	influencer-deals.net
>	31/03/2025, 10:20:34	182.45.67.89	dior-partners.com
>	01/04/2025, 10:20:34	182.45.67.89	influencer-deals.net
>	02/04/2025, 10:20:34	182.45.67.89	dior-partners.com

There were 2 Domains linked to the Malicious IP 182.45.67.89 :

influencer-deals.net

dior-partners.com

The Suspicious log in was initiated using an **outdated** browser, which was discovered using the User_Agent field.

Mozilla/5.0 (compatible; MSIE 5.0; Windows NT 5.2; Trident/4.1)

Incident Response and Further Threat Hunting:

Reviewed the Location of the suspicious log in using:

What is My IP address.com

IP Details For: 182.45.67.89

Decimal:3056419673

Hostname: 182.45.67.89

ASN:4134

ISP:ChinaNet Shandong Province Network

Services: None detected

Country: China

State/Region:Shandong

City:Jinan

Latitude:36.6683 (36° 40' 5.99" N)

Longitude:116.9972 (116° 59' 50.00" E)

← → ↻ 📄 whatismyipaddress.com/ip/182.45.67.89 🔍

☰  WhatIs MyIPAddress .com

IP Details For: 182.45.67.89

Decimal:	3056419673
Hostname:	182.45.67.89
ASN:	4134
ISP:	ChinaNet Shandong Province Network
Services:	None detected
Country:	China
State/Region:	Shandong

Hostname:	182.45.67.89
ASN:	4134
ISP:	ChinaNet Shandong Province Network
Services:	None detected
Country:	China
State/Region:	Shandong
City:	Jinan
Latitude:	36.6683 (36° 40′ 5.99″ N)
Longitude:	116.9972 (116° 59′ 50.00″ E)

Although Afomiya has no confirmed working location or VPN use, the above log in details differ and identify as suspicious and anomalous, as the log in event used the previously identified attacker IP **182.45.67.89**.

Afomiya's Public IP was confirmed as **109.52.231.254**, the above information is therefore **the Indication of Compromise**.

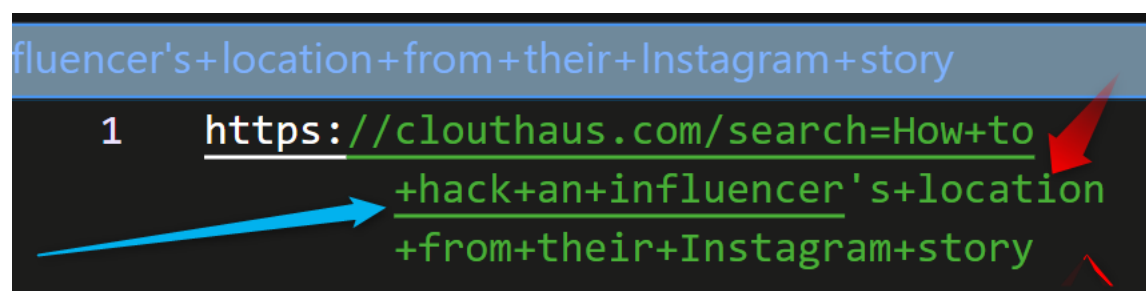
Reviewing the attacker's browser history of the CloutHaus website. To identify the attacker's intentions and the information targeted using the attacker's IP and the CloutHaus site name.

InboundNetworkEvents

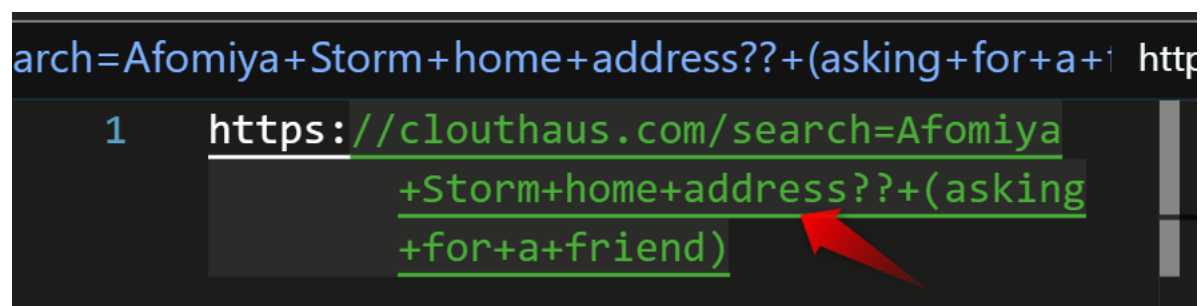
| where src_ip contains "182.45.67.89"

and url contains "clouthaus.com"

Based on the logs the attacker was specifically searching how to hack 'an IG influencers location, shared through their story'.

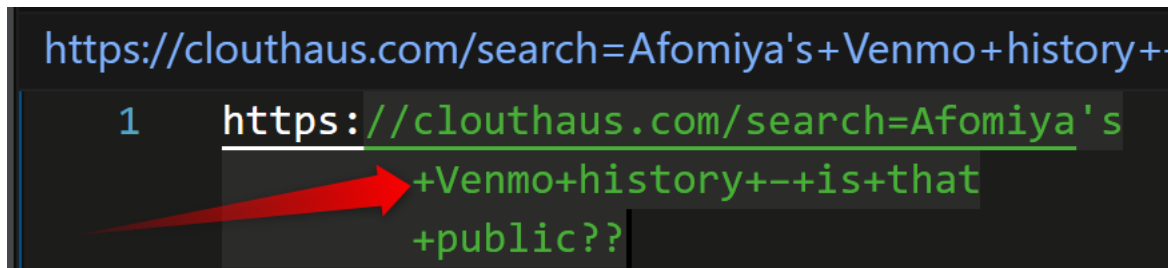


The attacker searched for Afomiya's **home address** for a friend.



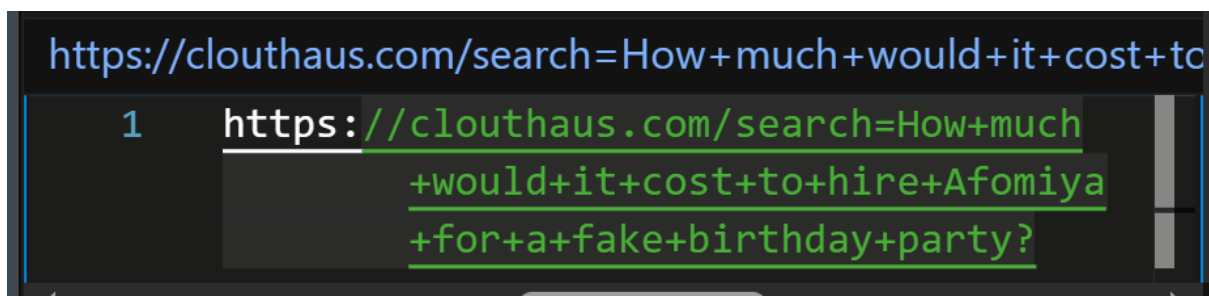
The attacker searched for the mobile and web **Payment Platform** used by Afomiya within the organisation, which was Venmo

```
https://clouhaus.com/search=Afomiya's+Venmo+history+-  
1 https://clouhaus.com/search=Afomiya's  
+Venmo+history+--+is+that  
+public??
```



Lastly the attacker queried the cost of hiring Afomiya as an influencer for a fake birthday, for future Phishing Orchestration.

```
https://clouhaus.com/search=How+much+would+it+cost+to  
1 https://clouhaus.com/search=How+much  
+would+it+cost+to+hire+Afomiya  
+for+a+fake+birthday+party?
```



Incident Response & Remediation Strategies:

Multi Factor Authentication Enforcement for access to all Business Applications and Services.

Password and Session Management to restrict and limit account compromise and further attacker escalation, immediate remote session terminations of all devices, immediate compliant password changes.

Intrusion Detection / Prevention System / SIEM to identify the anomalous and suspicious authentication / log in activity.

Email Security and Mailbox Monitoring to identify IOC, suspicious activity, unauthorised access, mailbox configuration, information gathering and persistence.

Role Based Access Control to limit and restrict information disclosure and privilege escalation.

Social Media Use Policy Enforcement to limit and restrict information disclosure, OSINT and exploitation.

